Day21_OWASP_Top10_2025

PART A — FUNDAMENTALS

1. What does OWASP stand for: Open worldwide Application Security Project

2. What is the purpose of the OWASP Top 10: Awareness document for major categories of web application security and risk clarification resource

3. Why is the OWASP Top 10 useful for cybersecurity students?
- Recognize common application security weaknesses
- Understand security terminology
- Communicate security findings
- Improve secure development awareness
- Prepare for vulnerability assessment
- Prepare for penetration testing
- Understand future web security labs

4. What is a vulnerability: Weakness

5. What is security risk?
- Describing what could happen because of a risk.

6. What is an asset?
- Something valuable that needs protection

7. What is a threat?
- Something that may cause harm by taking advantage of weakness.

8. What is impact?
- Possible consequences of security problem.

9. Explain Authentication.
- It explains who the user is.

10. Explain Authorization.
- It asks what are allowed to do by the user

11. What is the difference between Authentication and Authorization?
- Authentication: Who are you?
- Authorization: What are you allowed to do?

PART B — OWASP TOP 10:2025

Write one or two sentences explaining each category:

12. A01:2025 — Broken Access Control
Access control deciding who can accesss what if this fails anyone can access anything leading to data leak.

13. A02:2025 — Security Misconfiguration
When system configured insecurely leading to unnecessary features enabled, unsafe default headers and detailed production error messages so on…

14. A03:2025 — Software Supply Chain Failures
Modern application depending on Library, packages, frameworks, Build systems involving security risks in system and dependencies used to build, operate and distribute softwares.

15. A04:2025 — Cryptographic Failures
It helps protect security info failure leading to data leaks.

16. A05:2025 — Injection
Injection occurs when untrusted input is interprest as a part of command, query and injection as SQL/command.

17. A06:2025 — Insecure Design
Security Weakness caused by Ineffective o rmissing security design.

18. A07:2025 — Authentication Failures
Does not protect the process of identifying and authenticating users leading to weak authentication controls.

19. A08:2025 — Software or Data Integrity Failures
Without sofware or information being trustworthy it automatically fails.

20. A09:2025 — Security Logging and Alerting Failures
Security events should be recorded. Important events should generate appropriate alerts such as Multiple failed login attempts.

21. A10:2025 — Mishandling of Exceptional Conditions
Application encountering conditions such as operational erros, invalid output and resource failure and so on…

PART C — SAFE PRACTICAL ANALYSIS

Analyze these FICTIONAL scenarios.

SCENARIO 1:

A normal student can access an admin-only page.

Identify: Broken Access Control

Asset: Student and Administrative data

Security Problem: Student having Access to Admin page

OWASP Category: A:01:2025

Possible Impact: Access to unwanted information

Day21_OWASP_Top10_2025

High-Level Defensive Recommendation:Important role based access control and verify user permission on the server.

SCENARIO 2:

A production application displays internal file paths and detailed debug errors.

Identify: Security Misconfiguration

OWASP Category: A:02:2025

Why: The application exposes internal file paths due to debug errors.

SCENARIO 3:

A company unknowingly installs a compromised third-party software dependency.

Identify: Software Supply Chain Failure

OWASP Category: A: 04: 2025

Why: The company uses a compromised third-party software which introduce malicious code

SCENARIO 4:

A sensitive approval workflow was designed without an approval control.

Identify: Insecure Design

OWASP Category: A:06:2025

Why: The application was designed without an important security control to ensure sensitive action that require approval.

SCENARIO 5:

An application does not record important suspicious authentication activity.

Identify: Security logging and authentical failures

OWASP Category: A:09:2025

Why: Important suspicious authentication activity weren’t recorded neither gave an alert.

Day21_OWASP_Top10_2025

PART D — STUDENT PORTAL ASSETS

Imagine a fictional internship portal.

List five important assets.

Student Personal Information:
Information is private, could be misued for identity theft,phishing or impersonation.

Student CVs and Documents:
Personal and education information only accessible to authorized users.

Credentials and Authentication Data:
Attackers could stole credentials, session IDs to stole user account and impersonate them.

Internship Application and Records:
Unauthorised modification could affect students internship opportunties and application decisions.

Administrator account and Portal Database
Attacker gaining administrative access could delete, modify or steal data of personal informations.